

Social Media Vulnerability Dataset: Analysis Explanation and Findings

1. Purpose of This Work

This project studies social-media posts that mention software vulnerabilities, identified by CVE IDs. The main goal is to understand whether social-media activity can help explain or predict changes in exploitation risk.

The exploitation-risk signal used here is EPSS, the Exploit Prediction Scoring System. EPSS estimates the probability that a vulnerability will be exploited in the wild in the next 30 days.

The important question is not simply:

Are social-media posts correlated with EPSS?

The better question is:

When a CVE appears on social media, does that activity provide useful early signal about future EPSS movement or future known exploitation?

This distinction matters because EPSS already uses many public threat-intelligence signals. Also, LLM-generated summaries may contain prior public knowledge about CVEs. So the later stages of the analysis focus on original post dates, historical EPSS values, and external KEV labels instead of relying only on LLM summaries.

2. Dataset Overview

The dataset is stored in:

``/home/ayounas/Text_property_Graph/SummTPGVul/SummVul/Social_Media_Dataset/Data_Files``

It contains three CSV files:

- ``gemma_combined_summ.csv``
- ``gpt_combined_summ.csv``
- ``mistral_combined_summ.csv``

Each file has:

- 9,218 parsed CSV rows
- 28 columns
- the same core vulnerability and post metadata
- different LLM-generated summary fields

The three files should not be treated as three independent datasets. They are the same social-media/CVE dataset with three different LLM summary variants.

3. What One Row Represents

The row grain is:

one social-media post linked to one CVE

The `cve` column is not always just the canonical CVE. It usually looks like:

`CVE-2025-3600-1`

The canonical CVE is:

`CVE-2025-3600`

The final suffix is a row/post index. For vulnerability-level analysis, the suffix must be removed.

Important counts:

Item	Value
Rows per file	9,218
Base/canonical CVEs	5,692
Non-Telegram rows	6,628
Non-Telegram first-CVE events	4,187
Telegram rows excluded from temporal work	2,590

Telegram is excluded from temporal analysis because its dates are not true post-publication dates; they are message-crafting dates.

4. Important Dataset Attributes

The most important columns are:

Column or group	Meaning
`cve`	CVE identifier plus row suffix
`source`	Platform/source, such as Mastodon, Reddit, HackerNews, BleepingComputer, ExploitDB, Telegram
`date_posted`	Post date; valid for temporal work except Telegram
`time_posted`	Post time, but often `00:00` placeholder
`social_media_post`	Original post text
`epss_score`	Exploitation probability score
`epss_status`	Whether EPSS was original or enriched
`cvss_score`	CVSS severity score
CVSS submetrics	Attack vector, complexity, privileges, user interaction, scope, impacts
`occurrence_count`	Number/count feature related to how often a CVE appears
`sources_available`	Whether external source links exist
`github_links_with_code_available`	Whether GitHub code evidence exists
`source_links`	Advisory/reference URLs
`github_urls`	GitHub URLs
`summ_all_sources`	LLM summary of all external source links
`summ_github_urls`	LLM summary of GitHub evidence
`summ_cvss_metrics`	LLM explanation of CVSS metrics

5. Key Data Quality Findings

Several data-quality issues matter for modeling and interpretation.

5.1 Telegram Cannot Be Used for Timing

Telegram dates are not original publication dates. Therefore, Telegram is kept for non-temporal descriptive analysis but removed from temporal/event analysis.

5.2 HackerNews Rows Are Often Page Dumps

HackerNews rows are structurally different from normal posts. Many are very long page scrapes rather than single discussion posts. This can distort text modeling because the model may learn boilerplate or page structure instead of CVE-specific content.

5.3 Shared Post Text Is a Serious Contamination Risk

A large number of rows share the same post text across multiple CVEs. This means the same text can point to many different labels. If a text model sees this, it may learn non-specific text rather than true CVE-specific signal.

Important finding from the independent analysis:

- 684 unique texts map to more than one CVE
- 3,296 rows are affected
- this is 35.8% of the corpus

5.4 CVE Age Is a Major Confound

Older CVEs tend to have higher EPSS because there has been more time for exploitation evidence to accumulate. Newer CVEs often sit near the EPSS floor.

This means platform effects, post length effects, and source effects can be partly explained by the age of the CVEs those platforms discuss.

5.5 CVSS Is Not the Same as EPSS

CVSS measures technical severity. EPSS measures exploitation likelihood. They are not interchangeable.

The analysis found weak CVSS/EPSS association. At CVE level, the relationship can even reverse. So high severity does not automatically mean high exploitation probability.

6. Why LLM Summaries Were Treated Carefully

The dataset contains summaries generated by GPT, Gemma, and Mistral. These summaries are useful, but they also create risk:

1. LLMs may already know public facts about well-known CVEs.
2. LLM summaries may encode knowledge not present in the original social-media post.
3. Different LLMs have different styles, length, formatting, and hallucination rates.

The summary-quality analysis found:

Model	Main observation
Gemma	Best coverage and strongest CVSS faithfulness
GPT	Generally good but more truncation in source summaries
Mistral	More verbose and structured, but more hallucinations about CVEs not being real

For this reason, the later temporal and forward-looking analysis does not rely on LLM summaries as the main evidence. Instead, it uses original post dates, canonical CVEs, historical EPSS, and CISA KEV.

7. Analysis Flow

The full analysis was built in stages.

Stage 1: Dataset Inventory and Verification

We first verified:

- row counts
- column names
- missing values
- whether the three model files share the same core data
- whether Telegram should be excluded from temporal work
- whether the `cve` field needs canonicalization

Technique used:

- CSV parsing with Pandas
- independent row-count verification
- static-feature checksum comparisons
- missingness tables
- duplicate checks

Why:

Before modeling, we need to know the real structure of the data. Otherwise, we may accidentally treat repeated rows or summary variants as independent evidence.

Stage 2: Feature and Correlation Analysis

We studied:

- platform distributions
- EPSS distribution
- CVSS distribution
- CVSS submetrics
- GitHub/source-link evidence

- text length
- categorical associations
- numeric correlations

Techniques used:

- descriptive statistics
- Spearman correlation
- Pearson correlation as a secondary check
- categorical distribution tables
- Cramer's V for categorical association
- stratification by platform and CVE year

Why:

EPSS is highly skewed, so rank-based methods like Spearman are safer than relying only on raw linear correlation.

Stage 3: LLM Summary Quality Analysis

We compared summary fields across Gemma, GPT, and Mistral.

We checked:

- summary missingness
- summary length
- CVSS-score faithfulness
- hallucination patterns
- formatting patterns
- whether summaries mention EPSS

Why:

If summaries are later used as model features, we need to know whether they are complete, faithful, and comparable.

Stage 4: Temporal EPSS Event Analysis

For each canonical CVE, we used the first non-Telegram post date as an event date.

We retrieved historical EPSS around the event:

- 30, 14, 7, and 1 day before
- event day
- 1, 3, 7, 14, and 30 days after

Because many CVEs do not have EPSS on the exact event day, we used an event anchor:

EPSS at `t`, otherwise `t+1`, otherwise `t+3`

Technique used:

- event-study panel
- daily historical EPSS retrieval
- pre/post delta calculation
- Wilcoxon and t-tests
- stratified analysis by platform, CVSS severity, and baseline EPSS

Why:

This avoids using LLM text and instead asks whether EPSS changes around the actual social-media event date.

Stage 5: Temporal Feasibility Audit

Another audit showed that a full two-sided before/after event study is not feasible for the entire corpus.

Reason:

Most CVEs appear on social media close to when they enter EPSS. Therefore, many CVEs do not have enough pre-event EPSS history.

Important audit result:

Window	Events with enough pre-history
+/-7 days	852
+/-14 days	810
+/-30 days	773

After requiring CVE-specific first-post text:

Window	Usable events
+/-7 days	384
+/-14 days	346
+/-30 days	321

Why this matters:

The pre-history subset is biased toward older, already higher-EPSS CVEs. So the main analysis should not be a broad causal before/after study.

Stage 6: Forward-Looking Matched Study

The final implemented design is a forward-looking matched study.

Question:

After a CVE first appears on non-Telegram social media, does its EPSS percentile rise more than comparable CVEs that have not yet appeared in the corpus?

Control definition:

For each treated CVE, controls are CVEs from the same corpus whose first mention happens after the treated CVE's +30 day outcome window.

Matching uses:

- CVE year
- CVSS severity
- static CVSS/profile similarity
- baseline EPSS percentile proximity

We also enforce a baseline EPSS percentile caliper:

control must be within 0.10 percentile points of the treated CVE at baseline

Why:

This gives a fairer comparison than simply saying "EPSS rose after social media." We compare against similar CVEs over the same calendar window.

8. Main Results

8.1 Unmatched Forward EPSS Movement

Among treated CVEs with available outcomes:

Horizon	Events	Mean percentile delta	Median percentile delta	Increased
+7 days	4,092	0.04299	0.00125	81.92%
+30 days	4,088	0.06073	0.00612	83.93%

Simple reading:

Most CVEs increase in EPSS percentile after first social-media mention.

But this is not enough by itself because many CVEs may be increasing anyway.

8.2 Matched Control Results

After matching treated CVEs to not-yet-mentioned controls:

Horizon	Matched events	Mean ATT percentile delta	Median ATT	Treated rose more
+7 days	869	0.04534	0.000047	53.51%
+30 days	868	0.00178	0.000020	50.58%

Interpretation:

- At +7 days, treated CVEs rise more than matched controls.
- At +30 days, the matched effect mostly disappears.
- The short-term signal is stronger than the medium-term signal.

Clean first-post subset:

Horizon	Matched events	Mean ATT percentile delta	Median ATT	Treated rose more
+7 days	642	0.05463	0.000108	56.39%
+30 days	641	-0.00257	0.000090	51.01%

This suggests that cleaner, CVE-specific posts preserve the +7 day signal, but still do not support a strong +30 day matched effect.

8.3 CISA KEV Enrichment

CISA KEV gives an external known-exploitation label.

KEV metric	Count	Percent
CVEs in study	4,187	100.00%
Ever in KEV	284	6.78%
Added to KEV after social event	119	2.84%
Added to KEV within 90 days	102	2.44%

Interpretation:

Most CVEs in the corpus are not KEV-listed, but a meaningful minority are. KEV is useful because it is an external outcome, unlike EPSS which may incorporate public chatter.

8.4 Predictive Ablation Results

We tested whether different feature groups help predict future outcomes.

For predicting EPSS percentile increase by +30 days:

Feature set	ROC-AUC
CVSS only	0.6098
CVSS + baseline EPSS	0.7126
+ platform and attention features	0.7466

For predicting KEV within 90 days:

Feature set	ROC-AUC
CVSS only	0.6211
CVSS + baseline EPSS	0.6737
+ platform and attention features	0.9255

Interpretation:

Baseline EPSS adds useful information beyond CVSS. Platform and attention features add more signal. The KEV result is especially strong, but it should be treated carefully because KEV positives are rare.

9. What the Results Mean

The strongest conclusion is:

Social-media activity provides useful short-term forward signal around exploitation-risk movement, especially over the next 7 days.

The weaker conclusion is:

After matching, the +30 day EPSS effect is much smaller and not clearly stronger than controls.

The analysis does not prove that social media causes EPSS to rise. Instead, it shows that first social-media mention is a useful event marker for short-term risk movement.

In simple terms:

- Social media often appears when a vulnerability is becoming important.
- EPSS often rises after that point.
- But similar CVEs may also rise, so controls matter.
- The best-supported signal is short-term, not long-term causal impact.

10. Why the Final Design Is Better Than Simple Correlation

Simple correlation has problems:

- LLM summaries can leak prior knowledge.
- CVSS and EPSS measure different things.
- CVE age heavily affects EPSS.
- Platforms discuss different kinds of CVEs.
- Telegram dates are not valid event dates.
- Repeated posts and shared text can contaminate models.

The final design improves this by:

- using canonical CVEs
- excluding Telegram from timing
- anchoring on first valid post date
- using historical EPSS instead of one static EPSS score
- using percentile movement to reduce model-version problems
- adding matched controls
- adding CISA KEV as an external outcome
- reporting clean first-post subsets

11. Main Limitations

The analysis is stronger than simple correlation, but still has limitations.

1. Controls are internal to the corpus. They are not guaranteed to have no social-media attention anywhere; they are only not-yet-mentioned in this dataset during the outcome window.
2. KEV dates are catalog-addition dates, not necessarily first-exploitation dates.
3. HackerNews and shared-text rows can distort text-based models.
4. Platform and attention features may partly reflect how the dataset was collected.

5. The +30 day matched effect is weak, so the main claim should focus on short-term signal.

12. Recommended Future Improvements

The next best improvements are:

1. Build an external control universe from NVD/FIRST CVEs not observed in the social-media corpus.
2. Match controls on publication date, CVE year, CVSS, CWE, baseline EPSS percentile, and pre-event trend.
3. Add CISA KEV as a primary external outcome, not only an enrichment column.
4. Remove or repair shared-text contamination before training text models.
5. Treat HackerNews separately or extract only CVE-relevant text windows.
6. Compare model performance using:
 - CVSS only
 - CVSS + baseline EPSS
 - platform/attention features
 - original post text
 - Gemma summaries
 - GPT summaries
 - filtered Mistral summaries
7. Always split by base CVE when training models.

13. Final Takeaway

This dataset is valuable, but its best use is not proving that social media causes exploitation risk.

Its best use is:

studying whether early social-media attention improves prediction of future exploitation-risk movement.

The current evidence supports this:

- EPSS percentile often rises after first social-media mention.
- A matched +7 day signal remains after controls.
- The +30 day matched signal is weak.
- Platform and attention features improve predictive models.
- KEV enrichment gives an external exploitation signal.

The final defensible conclusion is:

Social-media activity is a useful short-term warning signal for vulnerability risk, especially when combined with baseline EPSS, CVSS, platform information, and attention features. It should be treated as a predictive signal, not as standalone causal evidence.

14. Main Output Files

Correlation and feature analysis:

`GPT\_Analysis/SMP\_correlation\_analysis\_report.md`

Temporal EPSS event analysis:

`GPT\_Analysis/Temporal\_EPSS\_Analysis/temporal\_epss\_event\_analysis\_report.md`

Forward matched study:

`GPT\_Analysis/Forward\_EPSS\_Study/forward\_epss\_matched\_study\_report.md`

Final explanation report:

`GPT\_Analysis/Final\_Explanation\_Report/social\_media\_epSS\_analysis\_explanation.md`

`GPT\_Analysis/Final\_Explanation\_Report/social\_media\_epSS\_analysis\_explanation.pdf`